

Hướng dẫn dành cho các đội tham gia cuộc thi CTF Attack-Defense – ASCIS 2024

1. Mục tiêu của Cuộc thi Attack-Defense

- **Phòng thủ:** Bảo vệ các dịch vụ mà bạn được giao từ việc bị đội đối thủ tấn công.
- **Tấn công:** Khai thác các lỗ hổng trên hệ thống của đội khác để chiếm cờ (flag).
- **Điểm số:** Bạn sẽ nhận được điểm cho việc giữ cờ của mình an toàn và tấn công chiếm cờ từ các đội khác.

2. Truy cập Hệ thống và Môi trường của Bạn

- Mỗi đội sẽ được cấp các **máy ảo Docker** riêng, nơi các dịch vụ đang chạy và cờ được bảo vệ.
- Bạn sẽ được cung cấp **tài khoản SSH “ctf”** để đăng nhập vào máy ảo của mình và thực hiện các hành động phòng thủ.
- **Tài khoản “ctf”:** Đây là tài khoản chính mà bạn sẽ sử dụng để truy cập, giám sát, và bảo vệ hệ thống. Tuy nhiên, tài khoản này bị giới hạn quyền chỉnh sửa trên một số tập tin và cấu hình hệ thống để đảm bảo tính công bằng.

Cách đăng nhập vào máy ảo Docker của đội bạn:

1. Sử dụng SSH để đăng nhập vào máy ảo của bạn: `ssh ctf@[IP-máy-ảo]`
2. Nhập mật khẩu được cung cấp cho tài khoản ctf.

3. Nhiệm vụ Phòng Thủ

Bảo vệ Dịch vụ và Flag:

- **Bảo vệ dịch vụ:** Dịch vụ của bạn có thể là một trang web, dịch vụ mạng hoặc cơ sở dữ liệu. Bạn cần giám sát và bảo vệ chúng khỏi các cuộc tấn công từ đội đối thủ. Đảm bảo rằng các dịch vụ này luôn hoạt động, không bị gián đoạn.
- Để kiểm tra trạng thái dịch vụ, bạn có thể sử dụng lệnh sau trong máy ảo:

`service [tên dịch vụ] status`

- **Bảo vệ flag:** Flag được đặt trong một tệp đặc biệt (thường là `/flag/flag.txt`). Đội bạn cần bảo vệ cờ này để không bị đội khác lấy được.

Giới hạn của tài khoản “ctf”:

- Tài khoản “ctf” **không có quyền truy cập hoặc thay đổi các tệp cấu hình hệ thống**. Bạn chỉ có thể chỉnh sửa các tập tin thuộc về dịch vụ mà bạn cần bảo vệ.
- Bạn có thể sửa đổi các tập tin cấu hình của dịch vụ và/hoặc hệ thống tường lửa (firewall) trong giới hạn được cho phép để bảo vệ các dịch vụ.

Một số hành động phòng thủ điển hình:

- **Sửa chữa lỗ hổng:** Tìm hiểu và khắc phục các lỗ hổng có thể bị khai thác trong dịch vụ của bạn (ví dụ vá lỗi cấu hình bảo mật, thay đổi cấu hình dịch vụ).

- **Cấu hình tường lửa:** Thiết lập các quy tắc tường lửa để bảo vệ dịch vụ khỏi các IP không đáng tin cậy (tùy theo yêu cầu của thử thách, bạn sẽ được cấp/không được cấp quyền chỉnh sửa tường lửa).

4. Nhiệm vụ Tấn Công

Khai thác lỗ hổng của đội khác:

- Mục tiêu của bạn là tìm và khai thác các lỗ hổng trong dịch vụ của các đội đối thủ. Khi khai thác thành công, bạn sẽ có thể lấy được flag của họ.
- **Cờ mặc định** được lưu trong tệp /flag/flag.txt trên máy ảo của đội khác, trừ khi có các quy tắc đặc biệt khác.

Cách tiếp cận tấn công:

- **Khai thác (Exploitation):** Sử dụng các kỹ thuật tấn công dựa trên lỗ hổng của dịch vụ (ví dụ như SQL Injection, Remote Code Execution).
- **Chiếm flag:** Sau khi khai thác thành công dịch vụ của đội khác, bạn sẽ tìm thấy flag trong tệp /flag/flag.txt. Lấy flag và gửi lên hệ thống để ghi điểm tấn công.

5. Hệ thống Thay Đổi Flag và Chấm Điểm

- **Thay đổi flag tự động:** Hệ thống sẽ thay đổi nội dung cờ (flag) sau mỗi khoảng thời gian nhất định. Vì vậy, các đội phải liên tục tấn công và bảo vệ flag mới.
- **Điểm phòng thủ:** Dịch vụ của bạn phải luôn hoạt động và flag phải được bảo vệ. Nếu dịch vụ của bạn bị ngừng hoặc bị tấn công, bạn sẽ bị trừ điểm.
- **Điểm tấn công:** Mỗi lần lấy được flag từ đội đối thủ, bạn sẽ nhận được điểm tấn công.

6. Hạn chế và Quy tắc

- **Không tắt dịch vụ:** Nếu bạn tắt dịch vụ để ngăn đội khác tấn công, hệ thống sẽ phát hiện và bạn sẽ bị trừ điểm.
- **Không phá hoại hệ thống:** Không được cố tình phá hoại hoặc làm sập máy ảo của đội khác ngoài mục tiêu khai thác lỗ hổng để lấy flag.
- **Tôn trọng luật chơi:** Tất cả các hành động phải tuân thủ luật của ban tổ chức. Mọi hành động gian lận hoặc phá luật sẽ bị xử lý nghiêm khắc.

7. Một số Lời khuyên

- **Phân chia công việc:** Nên phân chia đội của bạn thành hai nhóm, một nhóm chuyên phòng thủ và một nhóm chuyên tấn công để tối ưu hóa hiệu quả.
- **Liên tục kiểm tra dịch vụ:** Hãy thường xuyên kiểm tra tình trạng dịch vụ của bạn để đảm bảo rằng không bị đội khác tấn công thành công.
- **Theo dõi thay đổi flag:** Khi hệ thống thay đổi flag, bạn cần nhanh chóng cập nhật tình trạng bảo vệ flag của mình và chuẩn bị cho các đợt tấn công tiếp theo.